WEEK 1

Introduction: why cyber security matters to managers

Introduction – Parts 1, 2 and 3

IN ONE MINUTE

- Cyber security is a current, serious problem; more digital means more risk.
- It affects four units: individuals, organisations, society and government.
- Technology plays a **triple role**: source of threat, asset to protect, and tool for defence.
- Cyber security = information security + the security of individuals in the cyber world.
- The goal of security is **CIA**: confidentiality, integrity, availability.

Real incidents the professor used

- **Spear phishing**: an email that looked like it came from the IIT Madras director ("Can I have a quick moment?"). It came from a Gmail address. The attacker had researched who is who in the institute; this background study is **social engineering**. Ordinary phishing is random mass email; spear phishing is targeted and researched.
- Fake SBI "PAN verification" SMS leading to a look-alike login page. Lesson: always check the website address before signing in.
- **Ransomware**: the attacker encrypts your machine and demands money for the key. Kaseya point-of-sale attack (2021) stopped retail stores; hackers asked about $70 million. Chennai Corporation refused to pay because its PCs ran outdated Windows 8.
- AIIMS Delhi (Nov–Dec 2022): five servers hacked. Health data is super-sensitive; in the US it is protected by **HIPAA**.
- An EY survey: **91%** of organisations reported at least one cyber incident in a year.
- Connected cars (Tesla over-the-air updates); India's ICAT now tests cars for cyber security.
- Saudi Aramco refinery attack (16 Sept 2019, ~4 am, using drones); a US drone killed Qasem Soleimani. Drones and IoT bring physical danger into cyber security.
- IoT and Manufacturing 4.0: "any device connected to the internet is not safe."
- Air India data breach; Twitter accounts of celebrities hacked; TCS website hacked (it was outsourced).

Four summary points from Lecture 2

1. Cyber security is a current and serious problem. More digitisation brings more cyber problems; we will not go back, so we must manage the risk (like making cars safer instead of banning them).
2. It affects individuals, organisations, society and government.
3. Government has two concerns: its own systems and data can be attacked, and it must regulate (privacy and data protection are a "close cousin" of cyber security).
4. Technology plays a triple role: **source of threat** (e.g. scripts for a denial-of-service attack), **asset to be protected** (data centres, PCs), and **defence** (e.g. firewalls).

Definitions

TERM	MEANING IN THIS COURSE

Security	The quality or state of being secure, free from danger. It is also a psychological feeling of safety.
Cyber	From *cybernetics* (Greek, "steersman", i.e. control). Used since the 1990s for the internet-connected world.
Spelling	"cyber security" (two words) is the European convention, "cybersecurity" (one word) is American, "cyber-security" is the Indian compromise. Any is fine if used consistently.
Cyber security (ITU, 2008)	The collection of tools, policies, security concepts, safeguards, guidelines, risk management approaches, actions, training, best practices, assurance and technologies used to protect the cyber environment and organisation and user assets.
Information security	(Whitman & Mattord) Protection of information and its critical elements, including the systems and hardware that use, store and transmit that information.
Cyber vs information security	Information security is part of cyber security. Cyber security also covers people: cyber crime, cyber bullying, drone attacks. "Cyber security = information security + individuals."

Organisational security has many layers: physical, personal, operations, communications, network and information security.

What the course covers

- Cyber security from both **technological and administrative** perspectives (course learning objective 1). Is it a technology problem or a management problem? Both. The textbook is Whitman & Mattord's *Principles of Information Security*.
- **Zero trust** is the techie view: trust no human; let technology decide.
- Two kinds of management planning: **contingency planning** (reactive: something has gone wrong, restore normal operations) and **risk management** (proactive: prevent things from going wrong).
- Cryptography provides confidentiality. Analogy: a lecture in Greek: you can hear (access) it but can't understand it.
- Passive defence (walls, firewalls) vs active defence ("offence is the best defence", which raises legal issues).
- Privacy regulation in the US, Europe (GDPR) and India.

> FROM THE TEXTBOOK (ASKED IN ASSIGNMENTS)
>
> The assignment also uses these textbook ideas. **Protected Health Information (PHI)** is health data tied to an identity; sharing it without verified authorisation is a PHI breach. **Critical Infrastructure Protection** prioritises systems like SCADA controls for water and power. A firewall alone is never a complete information security programme; information security combines policy, awareness/training and technology (classification + awareness + endpoint tools = information security).

How they'll ask it

- Scenario questions: identify the attack (social engineering, spear phishing vs phishing vs vishing vs smishing, ransomware).
- Technology's triple role: in a scenario, is technology the threat, the asset, or the defence?
- Which CIA property is violated by a described event (modified record = integrity; leak = confidentiality; outage = availability).
- Critical infrastructure prioritisation (SCADA for water and power beats apps and websites).
- Information security is a programme (policy + people + technology), never a single tool.

WEEK 2

Foundations: CIA, access control and the Target breach

Foundation – Parts 1, 2 and 3

IN ONE MINUTE

- CIA triad = the purpose of cyber security. Know each word with an example.
- McCumber Cube: 3 dimensions × 3 = 27 cells, so nothing is missed.
- Identification → Authentication → Authorization → Accountability.
- Vulnerability (the weakness) vs exploit (using the weakness). False positive vs false negative.
- Target (2013): a breach despite heavy investment, because of management failures.

Components of information security

A diagram with three overlapping circles: **network security**, **computer & data security**, and **management of information security**. **Policy** sits in the centre where all three meet; it guides decisions such as how much to invest.

Computing does three things with data: **storage, processing and transmission**. Each must be secured.

The CIA triad

GOAL	MEANING	EXAMPLE / HOW IT'S ACHIEVED
Confidentiality	Only the intended recipient can read the information.	Rivest, Shamir & Adleman's (1978) Alice → Bob with eavesdropper Eve. Needs information classification, secure storage, policies, training, encryption (Caesar cipher).
Integrity	Information is whole, complete and unaltered.	Someone changes "10 years' experience" to "2" in your CV; date of birth wrongly entered as 2010 instead of 2000. Data subjects should be able to access and correct their data.
Availability	Information is available to authorised users when needed.	IRCTC database down when you book. Achieved through reliability and **redundancy**; contracted in SLAs as "nines" (99.999%). 100% availability has near-infinite cost.

Related concept: **accountability**, knowing who is responsible when something goes wrong, supported by sign-in logs.

McCumber Cube (NSTISSC security model)

Proposed by John McCumber. A cube with three dimensions, each with three values, giving 27 cells. A manager checks every cell so no aspect is missed.

DIMENSION	THREE VALUES
Information states	Storage, processing, transmission
Security goals	Confidentiality, integrity, availability
Safeguards (methods)	Policy, education, technology

Example cell: "integrity of data during processing, ensured through education".

Access control: four steps

Identification → Authentication → Authorization → Accountability

- **Identification**: creating a credible identity (Aadhaar enrolment, ID card, roll number, employee ID, account number). The hardest step; without identity you cannot ensure confidentiality.
- **Authentication**: verifying that you are who you claim to be. Password = something you know; fingerprint/biometric = something you are/have. Multi-factor authentication combines them.
- **Authorization**: the level of access you get after authentication, based on role (student vs faculty login in Moodle; hostel room vs faculty room). Requires classifying information and people and mapping them.
- **Accountability**: fixing responsibility after an incident (who was on guard?). Keep logs of sign-ins and sign-outs.

Key vocabulary

- **Vulnerability**: a weakness (the classroom door is unlocked).
- **Exploit**: using a vulnerability to break in (someone who knows the door is open walks in). Not every vulnerability gets exploited.
- **False positive**: something genuine is flagged as malicious (it disrupts operations, so staff are tempted to switch the alarm off).
- **False negative**: a real attack is missed (dangerous).
- Trade-off: tighter security usually reduces efficiency, and people then bypass security.

Case: Target Corporation (2013)

> WHAT HAPPENED
>
> US retailer (~1,797 stores, ~$72 billion revenue). During Thanksgiving/Christmas 2013, hackers stole customers' payment card data from point-of-sale (POS) terminals.
>
> HOW
>
> - Entry through a third-party vendor (an HVAC/climate-control company, Fazio Mechanical Services) whose access was not limited. The network was not segmented, so the vendor's access reached the POS systems: an **authorization** failure.
> - Malware called a **RAM scraper** read card data from POS memory. Data was encrypted in transmission but **not in the POS RAM** (technical vulnerability).
> - Target had a $1.6 million malware-detection tool installed six months earlier, security comparable to the CIA (the agency), audits and PCI compliance. But the automatic malware-deletion feature was **turned off** and warnings were ignored because of too many false positives. Logging was incomplete.
>
> IMPACT
>
> - Tangible: about $100 million in settlements (banks, card companies such as Visa, customers); more than 90 lawsuits; holiday-season profit fell 46%.
> - Intangible: loss of goodwill, customer trust and reputation. It was a watershed moment for US cyber security regulation.
>
> LESSONS
>
> - Investing in technology is not enough if management processes fail; employees can circumvent security.
> - Titanic analogy: Captain Smith ignored iceberg warnings because the sea looked calm. Never ignore safety warnings. Andrew Grove's book *Only the Paranoid Survive* (inflection points, 10× force): a paranoid mindset suits cyber security.

- $100M is tiny next to $72B ("a pickpocket"), so some firms choose to invest the bare minimum and pay fines. Competition and signalling trust push the other way.

FROM THE TEXTBOOK (ASKED IN ASSIGNMENTS)

Whitman & Mattord's critical characteristics of information: availability, accuracy, **authenticity** (genuine and original, not fabricated), confidentiality, integrity, utility, possession. Components of an information system: software, hardware, data, people, procedures, **networks** (networks move data between machines). Good access-control practice: role-based permissions, periodic review and revocation of rights, and audited access logs.

EXAM TRAP

An SQL-injectable input field *before* any attack is a **vulnerability**. The crafted SQL string that uses it is an **exploit**. A safe app quarantined as malware is a **false positive**; malware that slips through is a **false negative**.

How they'll ask it

- McCumber Cube: name the three dimensions and their values; which dimension a term belongs to.
- Vulnerability vs exploit vs threat in a scenario (before an attack = vulnerability; the crafted attack = exploit).
- False positive vs false negative in detection scenarios.
- Identification vs authentication vs authorization vs accountability.
- Target case: entry via vendor, RAM scraper, alerts ignored, management lessons.

Quick recall

1. **Three components in the information security diagram, and what sits at the centre?**
   → Network security, computer & data security, management of information security; policy at the centre.
2. **Three things computing does with data?**
   → Storage, processing, transmission.
3. **Define confidentiality, integrity, availability in one line each.**
   → Only intended people read it; it stays whole and unaltered; it's there when authorised users need it.
4. **How is availability usually achieved?**
   → Redundancy (and reliability), often specified in SLAs as 'nines'.
5. **McCumber Cube dimensions?**
   → Information states (storage, processing, transmission); security goals (C, I, A); safeguards (policy, education, technology). 27 cells.
6. **Who proposed the Alice–Bob–Eve picture of confidentiality?**
   → Rivest, Shamir and Adleman (1978).
7. **Identification vs authentication?**
   → Identification creates/claims an identity; authentication verifies the claim.
8. **What is authorization?**
   → The level of access granted after authentication, based on role.
9. **What supports accountability?**
   → Logs of who signed in and out and what they did.

WEEK 3

Governance, Risk and Compliance (GRC)

Security management, GRC – Parts 1, 2 and 3 ·Case: iPremier (A)

IN ONE MINUTE

- Three approaches: GRC framework, standards-driven (ISO / NIST), textbook organisational-planning approach.
- GRC frameworks: **COBIT** (ISACA, IT community), **COSO** (accounting, internal control), **COSO ERM** (enterprise risk).
- Standards: BS 7799 → ISO/IEC 17799 → **ISO/IEC 27001** (PDCA). NIST is the open, free US alternative.
- Controls are preventive, detective or corrective.
- iPremier: a DDoS attack on a company with no plans, no logs and a weak hosting partner.

Why GRC

Breaches keep growing (Marriott 2019: about 500 million records). "Fortune favours the prepared mind" (Louis Pasteur): hope for the best, prepare for the worst.

Three approaches to managing cyber security

1. **GRC approach** (framework-based): cyber risk is one of many enterprise risks managed together under Enterprise Risk Management (ERM), alongside operations risk, market risk and so on. The broadest approach.
2. **Standards-driven approach**: cyber security treated separately, by implementing a standard from ISO or NIST. Suits small and mid-size firms; can also sit inside a GRC framework.
3. **Textbook (organisational planning) approach**: cyber security is a priority in strategic planning, together with contingency planning.

After the 2016 debit-card breach, the RBI made cyber security a strategic function in banks, separate from IT (and chip cards mandatory). Education has no such mandate, so no CISO is required there.

Governance vs management

Governance is higher than management. The board (governing body) puts management in place and then **evaluates, directs and monitors** it. Linking cyber security to governance makes it a strategic priority.

The **Sarbanes-Oxley Act (SOX)** came after accounting scandals such as Enron. IT systems then became the way to implement controls and compliance.

The three GRC frameworks

FRAMEWORK	WHO MADE IT	FOCUS
COBIT	ISACA (Information Systems Audit and Control Association). Stands for Control Objectives for Information and related Technology. Current version discussed: COBIT 5.	IT-based governance of the whole enterprise, end to end. Principles: meeting stakeholder needs, covering the enterprise end to end, a single integrated framework, a holistic approach, separating governance from management. Management cycle: **Plan (APO)** → **Build (BAI)** → **Run (DSS)** → **Monitor (MEA)**; governance: Evaluate, Direct, Monitor.

COSO	Committee of Sponsoring Organizations (accounting community; the lecture credits the American Accounting Association).	Internal controls. Original components include risk assessment, control activities, information & communication, monitoring, control environment.
COSO ERM	COSO, expanded	Enterprise Risk Management. Adds three elements: **objective setting, event identification, risk response**. Risk response closes the loop.

What internal controls protect

Safeguard assets, keep sufficient records, give accurate and reliable information, prepare financial reports to set criteria, improve operational efficiency, encourage adherence to management policies, comply with laws and regulations.

Types of control

Preventive: deter problems	**Detective**: find problems	**Corrective**: fix after detection

Like preventive, breakdown and corrective maintenance in a factory.

Standards for cyber security

- **BS 7799** (British Standard) → adopted by ISO as **ISO/IEC 17799:2005** (133 possible controls) → renamed the **ISO/IEC 27000 series**.
- **ISO/IEC 27001**: the basic standard, written in the **PDCA** cycle (Plan–Do–Check–Act) for continual improvement. ISO/IEC 27002 is the code of practice.
- Over 50 standards in the series for "verticals" (e.g. **ISO 27799**: information security management in health, using ISO/IEC 27002) and "horizontals" (e.g. network security, infrastructure).
- **NIST** (National Institute of Standards and Technology, USA). Preferred in the US (military). NIST standards are **open and free** (e.g. the computer security handbook SP 800-12); ISO standards are proprietary and paid.
- Why ISO still dominates despite NIST being free: service and support for implementation, and reputation. Like open-source vs proprietary software.
- Consultants try to sell you many standards; standards also have regional politics (ISO is European).

Case: iPremier, Part A (DDoS attack)

> THE COMPANY
>
> Online seller of luxury, rare and vintage goods; over 1 million customers (2017); one of the top two (rival: MarketTop). Its edge is customer experience. Intense culture, pay through stock options, quarterly reviews.
>
> PEOPLE
>
> Bob Turley (new CIO, 3 months), Jack Samuelson (CEO), Tim Mandel (CTO, co-founder), Warren Spangler (VP Business Development, worried about stock/PR), Peter Stewart (legal counsel: "cut the connection"), Joanne Ripley (operations team leader), Leon Ledbetter (new ops staff).
>
> WHAT HAPPENED
>
> - 4:30 am: website unreachable, emails saying "ha ha ha". A **SYN flood from multiple sites** hit the router running the firewall: a distributed denial-of-service attack using zombies.
> - The business continuity plan binder was out of date; incident response had never been practised.

- Qdata, the hosting provider, was weak (chosen for proximity, personal ties). Joanne was not even let into the data centre.
- Detailed logging had been switched off to improve customer experience by about 20%, so there was no evidence.
- The attack stopped on its own (around 5:26 am). Nobody knew if data had been stolen.

CONCEPTS

- **DoS**: overwhelm an internet-connected asset so legitimate users can't use it (crowd blocking the doors of a Mumbai local train). **DDoS** uses many machines (a **botnet** or zombie network infected via malware/phishing).
- Motives: hacktivism, cyber vandalism, cyber warfare, extortion, rivalry.

LESSONS

No cyber security strategy, a stock-price obsession, no IR/DR plan, no logs, a weak outsourcing partner. The professor's point: shutting down an online business in a competitive market may kill it, but the attack stopped "at the attacker's mercy" without diagnosis, so the company had to investigate. A hot, warm or cold standby site should have existed.

FROM THE TEXTBOOK (ASKED IN ASSIGNMENTS)

Goals of information security governance: **strategic alignment, risk management, resource management, performance measurement** (and value delivery). Information security governance = applying corporate governance principles to the security function. COBIT is *not* "a framework to organise business processes". **NIST Cybersecurity Framework** has three parts: Core, Implementation Tiers, Profiles (no "Framework control"). **ISO 31000** = risk management; **ISO 27001** = information security, and it suits organisations of every size. COSO's components do *not* include "risk response" (that comes in COSO ERM).

De facto standard: widely adopted without a formal body. **De jure standard**: formally approved by a standards body. **Guidelines**: non-mandatory recommendations. **Practices**: examples of actions that show compliance.

How they'll ask it

- Who made which framework: COBIT (ISACA), COSO (accounting/Treadway), NIST (US), ISO (international).
- What COSO ERM adds over COSO (objective setting, event identification, risk response).
- NIST CSF parts: Core, Tiers, Profiles.
- ISO 31000 (risk) vs ISO 27001 (information security); ISO 27001 suits any size.
- Standards lineage: BS 7799 → ISO/IEC 17799 → ISO/IEC 27000 series; PDCA.
- Definitions: de facto vs de jure standard; guideline vs practice.

Quick recall

1. **Three approaches to cyber security management?**
   → GRC (framework) approach, standards-driven approach, textbook organisational-planning approach.
2. **Governance vs management?**
   → Governance (the board) evaluates, directs and monitors; management runs the organisation.
3. **What led to SOX?**
   → Accounting scandals such as Enron.

WEEK 4

Contingency planning

Contingency planning – Parts 1, 2 and 3 ·Case: iPremier (B & C)

IN ONE MINUTE

- Contingency planning is **reactive**: an incident has happened; restore normal operations at minimum cost and time.
- Three plans chosen by impact: **IRP** (low) → **DRP** (high, same site) → **BCP** (move to another site).
- **BIA** analyses business processes. Its timings: **MTD = RTO + WRT**; RPO comes from the backup policy.
- Balance cost of disruption against cost of recovery; the optimum is where they cross.
- Hot, warm and cold sites. Red, blue and purple teams for testing.

Why plan, and the money problem

- Without a plan, people fall into **emotion-focused coping**: yelling, running away, hoping nothing is wrong (as at iPremier).
- **IVK case** (HBS): a new IT director proposed an intrusion detection system (IDS). The steering committee rejected it two years running because finance asked, "What is the ROI?" Lesson: security spending doesn't create revenue; it **reduces expected cost**. Quantify: expected loss without the investment vs with it. The saving must exceed the investment. Qualitative arguments don't convince finance. Cyber insurance is still hard to price.
- "If you fail to plan, you are planning to fail" (Benjamin Franklin). JFK's 1961 moon goal included returning the astronaut *safely*: build security into goals.

Two kinds of information security planning

Organisational planning (prevent)

Strategic (long term, 3–5 years) → Tactical (medium term, 1–2 years) → Operational (day to day). Security plans run alongside each. Values, vision and mission statements come first; strategic planning is top-down.

Contingency planning (react)

Incident Response Plan, Disaster Recovery Plan, Business Continuity Plan. Goal: restore normal operations with minimum cost and disruption.

CISO (Chief Information Security Officer) usually reports to the CIO and drafts security policy, plans, budgets and compliance. RBI mandates a top security role in banks. The **CPMT** (Contingency Planning Management Team) oversees contingency planning in large organisations.

IRP vs DRP vs BCP

PLAN	WHEN	TYPICALLY LED BY
Incident Response (IRP)	Low impact; operations continue (virus on one PC).	Technical team
Disaster Recovery (DRP)	High impact; operations stop but are restored **at the original (primary) site**.	CIO

Business Continuity (BCP)	So severe that operations must **move to an alternate site** (Chennai floods: IT firms moved out).	CEO

An **incident** is an attack that actually happened by exploiting a vulnerability. A **threat** is something that could happen. Analogy: shoe soles give grip, but you can still slip on a banana peel in the rain.

Business Impact Analysis (BIA)

The most important assessment in contingency planning. Its unit of analysis is the **business process** (risk management uses **assets**). For each automated process, ask: what is the impact if it goes down?

TERM	MEANING
MTD	**Maximum Tolerable Downtime**: total outage the process owner (not the tech team) will accept. Owners say "zero", but zero has an enormous cost.
RTO	**Recovery Time Objective**: time to bring the system back live.
WRT	**Work Recovery Time**: time after the system is live until work actually resumes (testing, sign-ins, checks).
RPO	**Recovery Point Objective**: the point in time to which data can be recovered. Set by backup policy: hourly backups give RPO = 1 hour.

```
MTD = RTO + WRT        (example: MTD 72 h, RTO 36 h → WRT 36 h)
```

FIPS 199 can be used to rate impact on confidentiality, integrity and availability as low, moderate or high.

Cost balancing

The shorter the downtime you want, the higher the **cost of recovery** (redundancy, hot sites). The longer the downtime, the higher the **cost of disruption**. The optimum is where the two curves cross. "Contingency planning is a negotiation for time," and management must be willing to pay for redundancy.

Incident response and continuity

- IR is organised before, during and after the incident. Document every incident: what, when, where, why and how. Hold an after-action review.
- Incident indicators (Pipkin): **possible, probable, definite**. Changes to logs are a definite indicator.
- Law enforcement and disclosure: under GDPR a breach must be reported within **72 hours**.
- BCP site strategies: **hot site** (fully configured, parallel, ready immediately), **warm site** (ready within a defined time), **cold site** (basic space, longest to activate); also time-shares, service bureaus, mutual agreements.
- Testing: drills and simulated attacks. **Red team** attacks, **blue team** defends, **purple team** moderates and draws lessons. Carnegie Mellon's IR plan is an example of a detailed plan.

Case: iPremier, Parts B and C

> PART B
>
> - iPremier publicly disclosed a DDoS attack lasting 75 minutes.
> - Files were checked only by name and size, not content, so tampering couldn't be ruled out.
> - Joanne Ripley recommended disconnecting all production computers and rebuilding from development files (24–36 hours). Others wanted to keep running and build a new site in parallel.

- Measures adopted: phased restart, file-by-file checks, a move to a modern hosting facility, a better firewall, more disk space and high-level logging (previously off because of a 20% performance penalty), staff training, an incident response team with simulated attacks, a security consultant and third-party audits.

PART C

- Management chose *not* to shut down. About two weeks later the FBI called: an iPremier production machine was attacking a competitor (MarketTop). The firewall had been breached; the DDoS was a diversion.
- New dilemmas: rebuilding now could destroy evidence; MarketTop might sue; possible theft of card data (breach of card-processing agreements); what to tell the public.

REAL-WORLD COMPARISONS FROM THE STUDENTS

Google Cloud Armor stopped an HTTPS DDoS peaking at 46 million requests per second (June 2022) using rate limiting and defence in depth. GitHub (2018) used Akamai Prolexic. Mitigations: reduce the attack surface, CDNs, know normal vs abnormal traffic, plan for scale and load balancing, DDoS protection services, better firewalls.

FROM THE TEXTBOOK (ASKED IN ASSIGNMENTS)

A **contingency plan** anticipates, reacts to and recovers from events that threaten information assets; IRP, DRP and BCP are its parts. **Business resumption planning (BRP)** = a combined DRP and BCP plus recovery teams. Strategic plans → tactical plans → operational plans (not the other way round); tactical plans cover 1–2 years.

Textbook IR has three phases: **detection, reaction, recovery**. Planning is separate, so "four phases including planning" is **false**. Incident classification decides whether an "incident candidate" is a real incident. BIA is a preliminary CP step done after the CP policy, common to CP and risk management, and its first phase prioritises business processes by contribution to the mission. The BC plan runs *alongside* the DR plan when damage is major, not only when DR fails.

Definite indicators: use of dormant accounts, changes to logs, presence of hacker tools, notification by partner or peer, notification by the hacker. **Probable**: activities at unexpected times, presence of new accounts, reported attacks, notification from an IDPS. **Possible**: unfamiliar files, unknown programs or processes, unusual consumption of computing resources, unusual system crashes.

How they'll ask it

- IRP vs DRP vs BCP: choose by impact and site; who leads.
- BIA terms and arithmetic: MTD = RTO + WRT; RPO from backups.
- Hot / warm / cold site definitions.
- Incident indicators: definite vs probable vs possible lists.
- Textbook facts: BRP = DRP + BCP; planning hierarchy strategic → tactical → operational; IR = detection, reaction, recovery.

Quick recall

1. **Main goal of contingency planning?**
   → Restore normal operations with minimum cost and disruption.
2. **Lesson of the IVK case?**
   → Security investments must be justified by quantified cost savings; finance asks for ROI.

WEEK 5

Cyber security policy

Cyber security policy – Parts 1, 2 and 3 · Article: "Internet Insecurity" (HBR)

IN ONE MINUTE

- Policy is the binding **reference document** for security decisions and priorities.
- Policy must never conflict with the law (Enron / Arthur Andersen shredding policy).
- Policy → standards → procedures & guidelines.
- Three levels: **EISP** → **ISSP** → **SysSP**.
- SETA = Security Education, Training and Awareness.
- Bochman: "cyber insecurity"; protect the crown jewels by reducing digital pathways (CCE / CIE).

What a policy is

- Rules vs **regulation** (legally enforceable) vs **norms** (social expectations, like dressing well for class). A policy that is enforceable in law is a regulation.
- A policy applies to everyone, for the collective good and fairness (course policies on plagiarism and exams).
- Policy influences progress: India's IT industry grew after policy changes (software technology parks, 1991 liberalisation).
- A badly framed policy (e.g. no internet access) leads to violations. Balance protection against progress. The terms of reference for Justice B.N. Srikrishna's committee: protect privacy *without inhibiting the potential of digital technologies*.

Principles for a good policy

1. It should **never conflict with the law** and must stand up in court.
2. It must be properly supported and administered (implemented, e.g. a firewall that actually blocks illegal sites).
3. It should contribute to the success of the organisation.
4. It should involve end users in its formulation.

> EXAMPLE: ENRON AND ARTHUR ANDERSEN
>
> Auditor Arthur Andersen adopted a document-retention ("shredding") policy: keep documents "while relevant". It then shredded audit evidence. Courts saw this as destruction of evidence: a policy in conflict with the law. Retention rules today use specific periods (IITM keeps answer scripts about four years).
>
> EXAMPLE: ILLEGAL SITES AT WORK
>
> If an employee accesses child pornography at work, the organisation can defend itself only if it has a clear policy (internet for work only; no illegal sites) *and* enforces it (blocks sites via firewall). That is due diligence.

Policy, standards, procedures, guidelines

- **Policy**: broad, abstract, strategic, long-term, rarely changed. ("Comply with the law of the land.")
- **Standards**: more detailed statements of how the policy is implemented. (If breach reporting changes from 72 to 24 hours, update the standard, not the policy.)
- **Procedures and guidelines**: step-by-step implementation (e.g. firewall configuration rules).

- Policy must be **disseminated** to employees (e.g. the Tata Code of Conduct).
- **SETA**: Security Education (long-term concepts, like this course), Training (immediate practical skill), Awareness (drills, updates).

Three levels of security policy

LEVEL	WHAT IT DOES	EMAIL EXAMPLE
EISP	**Enterprise Information Security Policy**: sets strategic direction, scope and tone; assigns responsibilities. Contents: statement of purpose, definitions/elements of information security, need for security, roles and responsibilities (e.g. a CISO), reference to standards (NIST/ISO).	"Employees will be given email, to be used per procedures."
ISSP	**Issue-Specific Security Policy**: detailed, targeted guidance on using a technology or resource (email, web, viruses, hacking tools, work from home, BYOD). Also **indemnifies the organisation** against liability.	Storage space, no personal use of official email.
SysSP	**System-Specific Security Policy**: implementation level. Two parts: **managerial guidance** and **technical specifications** (access control lists and configuration rules).	Mail server configured to a 5 GB quota.

- **Indemnify**: to absolve of responsibility. Hospitals indemnify doctors; an ISSP protects the organisation when an employee misuses resources.
- **Access control list (ACL)**: maps users/roles to the resources they can access and how (read, write, create, modify, delete, compare, copy), plus when, where and how access is allowed. Example: Windows XP roles (administrators, backup operators, guests, power users).
- **Configuration rules**: firewall rules (which sites/IPs are allowed), IDS rules.
- **Firewall** prevents access (preventive). **IDS** only detects and raises an alarm.

Article: "Internet Insecurity" (Andrew Bochman, HBR)

- Bochman is a senior grid strategist at the **Idaho National Laboratory (INL)**. Core claim: if a critical system is digital and connected, it *will* be compromised. No amount of spending guarantees safety.
- Statistics quoted: about 1,168 weekly attacks per organisation (Q4 2022); global security spending heading to ~$460 billion by 2025.
- Critical infrastructure (energy, telecom, transport, water) is interconnected, so failures cascade. Examples: Saudi Aramco (Shamoon wiper 2012, ~35,000 machines; 2017 safety-system attack; 2021 $50M extortion via a contractor), Ukraine's grid, the RedEcho campaign against India's grid.
- **Cyber hygiene** (patching, passwords, training, segmentation, asset inventory) is necessary but not enough against a determined attacker.
- INL's answer: identify the most critical functions ("crown jewels"), map the digital terrain, cut digital pathways, add analog/manual backups and redundancy, use air gaps. Think like the adversary and war-game it.
- **CCE** (Consequence-driven Cyber-informed Engineering), 4 phases: consequence prioritisation → system-of-systems analysis → consequence-based targeting → mitigations and protections. Aimed at nation-state-level threats.
- **CIE** (Cyber-Informed Engineering): build cyber security in from the concept and design stage; treat cyber attack as one more failure mode.

> FROM THE TEXTBOOK (ASKED IN ASSIGNMENTS)

> Whitman's definitions: **standards** are detailed mandatory statements; **guidelines** are non-mandatory recommendations; **procedures** are step-by-step instructions; **practices** are examples of actions that show compliance. EISP sections: statement of purpose, information security elements, need for security, roles and responsibilities, reference to other standards. "Authorized access and usage of equipment" is an **ISSP** section, not EISP.
>
> For a policy to be enforceable it must be shown to be: **disseminated** (available for review), **readable** (intelligible form), **understood** (comprehension), **agreed to** (compliance by act or affirmation), and **uniformly enforced**.
>
> Three ways to manage ISSPs: independent documents, one comprehensive document, or a **modular** document. SysSPs can be developed with or before ISSPs. **Managerial guidance** SysSPs state management's intent from a business view; **technical specification** SysSPs are the ACLs and configuration rules. A **capability table** lists what each *user* can access; the ACL lists who can access each *asset*. **Configuration rules** govern how a security system reacts to data it receives. Cyber hygiene = routine practices for digital health; cyber security is the broader strategy.

How they'll ask it

- Policy vs standard vs guideline vs procedure vs practice definitions.
- EISP vs ISSP vs SysSP: which section belongs where.
- Conditions for an enforceable policy (dissemination, review, comprehension, compliance, uniform enforcement).
- ACL vs capability table vs configuration rules.
- Bochman / INL: CCE vs CIE; cyber hygiene vs cyber security.

Quick recall

1. **What is a policy in this course?**
   → A binding reference document guiding security decisions and priorities.
2. **Regulation vs norm?**
   → Regulation is legally enforceable; a norm is a social expectation.
3. **First principle of good policy?**
   → It must never conflict with the law.
4. **Enron / Arthur Andersen lesson?**
   → A vague 'retain while relevant' shredding policy enabled destroying evidence: a policy conflicting with law.
5. **What makes an organisation defensible if an employee visits illegal sites?**
   → A clear policy plus enforcement (e.g. firewall blocking): due diligence.
6. **SETA?**
   → Security Education, Training and Awareness.
7. **EISP contents?**
   → Statement of purpose, information security elements/definitions, need for security, roles and responsibilities, references to standards.

WEEK 6

Risk management

Risk Management – Parts 1, 2 and 3 · Case: Protecting the Cheddar

IN ONE MINUTE

- Risk management is **proactive**; its unit is the **asset**.
- Sun Tzu: know yourself (assets) and know the enemy (threats).
- Three phases: **identification → assessment → control**. Goal: reduce risk, not eliminate it.
- Residual risk is what remains after current protections.
- Risk = LF × LM − % mitigated by current controls + measurement uncertainty. Practise the calculation.

Ideas behind risk management

- Sun Tzu (about 500 BC): "If you know the enemy and know yourself, you need not fear the result of a hundred battles. If you know yourself but not the enemy, for every victory gained you will also suffer a defeat. If you know neither, you will succumb in every battle."
- Risk management = **identifying, assessing and reducing** risk facing an organisation.
- **Attack surface** (attack vector): a 2-D picture with threats on one axis and assets on the other. A "vector" has more than one dimension (unlike a scalar). Equifax's 2017 breach has been charted this way.
- **Residual risk**: risk left after (1) base protection (e.g. built into the OS), (2) extra safeguards (antivirus, firewall), (3) closing vulnerabilities (patches). Risk identification and assessment really estimate residual risk.

The three phases

PHASE	WHAT YOU DO
1. Risk identification	Identify, inventory and categorise assets; classify, value and prioritise assets; identify and prioritise threats; specify asset vulnerabilities (TVA).
2. Risk assessment	Determine loss frequency; evaluate loss magnitude; calculate risk; assess risk acceptability.
3. Risk control	Select a strategy, justify it (cost-benefit), implement and monitor. It never stops.

Assets

- Six categories: **people, procedures, data, software, hardware, networking**. People are assets too (cyber bullying targets a person).
- Each asset gets a tag/ID (like a database primary key) with attributes: name, IP address, MAC address, type, serial number, manufacturer, version, location, owner. People get a security clearance level; data gets owner, creator, size, storage location, online/offline, backup.
- Data classification for a business: public, for official use only, sensitive, classified. US military: unclassified, sensitive but unclassified, confidential, secret, top secret.
- **Asset value** depends on business impact, not purchase price. Questions: Which asset is most critical to success? Generates most revenue? Most profit? Most expensive to replace or protect? Would cause most

liability or embarrassment if revealed?

- **Weighted factor analysis**: score each asset against weighted criteria (impact on revenue, profitability, public image) for a score out of 100. "Customer order via SSL" scored 100 because without it the business stops.

Threats

There are hundreds. **Threat intelligence** (likelihood and impact of current threats) comes from *outside* the firm (CERT, paid subscriptions); asset valuation is done internally. Threats are grouped into 12 categories:

CATEGORY	EXAMPLE
Compromises to intellectual property	Piracy, copyright infringement
Deviations in quality of service	Power or ISP outages
Espionage or trespass	Unauthorised access and/or data collection; an insider betraying the organisation
Forces of nature	Fire, flood, earthquake
Human error or failure	Accidents, employee mistakes
Information extortion	Blackmail threat of disclosure; ransomware
Sabotage or vandalism	Damage to or destruction of systems or information
Software attacks	Viruses, worms, DoS
Technical hardware failures	Equipment failure
Technical software failures	Bugs, code problems
Technological obsolescence	Running critical systems on out-of-date software (Windows 8)
Theft	Illegal confiscation of equipment or information

Threats can be ranked by **weighted rank = mean × weight** (a Communications of the ACM survey).

Vulnerabilities and the TVA worksheet

- A vulnerability always belongs to a specific **asset–threat pair**. Example: list every threat against one DMZ router and describe its vulnerabilities.
- **TVA worksheet** (Threats–Vulnerabilities–Assets): threats ranked on one axis, assets ranked on the other; each cell records vulnerabilities. The top-left cells are the most critical.

Calculating risk

```
Loss Frequency (LF) = likelihood of attack × probability of success
Loss Magnitude (LM)  = asset value × % of asset lost (exposure)

Risk = (LF × LM) – (% risk mitigated by current controls) + measurement uncertainty
```

> WORKED EXAMPLE FROM THE LECTURE
>
> E-commerce database: 10% chance of attack this year, 50% chance of success, asset value 50 (on 0–100), 80% would be compromised, estimates 75% accurate, no current controls.

```
LF = 0.1 × 0.5 = 0.05
LM = 50 × 0.8  = 40
LF × LM = 2
Uncertainty = 25% × 2 = 0.5
Risk = 2 + 0.5 = 2.5
```

In practice risk is often assessed qualitatively because good numbers are hard to get.

Case: Protecting the Cheddar (HBR)

- Newhouse Cheese Company, founded 1811 by Cole Newhouse (an immigrant from Wales; tagline "From Wales with love"). Fifth-generation CEO Chadwick (Chad) Newhouse digitised precision control.
- **Ransomware**: hackers shut down a temperature-control device as a demonstration and claimed to have the secret recipes. On his lawyer's advice, Chad wired **$49,999**.
- CISO Frank Armen wanted more intrusion monitoring, but the firm had already spent about $6 million while breaches rose. Sara (deputy to the CEO) asked why the systems were online at all and suggested putting humans back in the loop.
- Consultant Jack Parem used the four-step CCE approach: identify critical functions → map the digital terrain → find the likely attack paths → generate mitigation options. He found four pathways into the network; hackers could reach the industrial control systems; a bot had compromised one system; his own penetration test reached the recipes.
- Recommendations: take the thermization process offline; remove networked temperature controls or back them up with manual controls. CFO Bruce Boyle: "Going offline would kill the bottom line." The consultant: "Ransomware doesn't scare me; listeria does."
- Discussion: a hybrid approach (least privilege, compartmentalisation, manual backup) has costs (sunk investment, investor perception, retraining) and human error remains.
- **RaaS** (Ransomware as a Service) is a business model; ransoms often in cryptocurrency. WannaCry (attributed to North Korea) and NotPetya (attributed to Russia; didn't unlock even after payment).

FROM THE TEXTBOOK (ASKED IN ASSIGNMENTS)

Risk appetite: the quantity and nature of risk an organisation is willing to accept when trading off perfect security against unlimited accessibility. Residual risk is a combined function of a threat *less* threat-reducing safeguards, a vulnerability *less* vulnerability-reducing safeguards, and an asset *less* asset-value-reducing safeguards. "Specify asset vulnerabilities" is part of risk **identification**, not assessment. The goal of risk assessment is a relative risk rating for each vulnerability of an asset.

US national security classification: **Top Secret** = exceptionally grave damage; **Secret** = serious damage; **Confidential** = damage.

Matching: risk identification = recognising, enumerating and documenting risks; risk assessment = determining the extent of exposure; risk control = applying safeguards to reduce risk to an acceptable level; risk management = the whole process. Ransomware through a compromised router = **information extortion**.

How they'll ask it

- Numerical: compute risk with LF, LM, controls and uncertainty.
- Which activity belongs to identification vs assessment vs control.
- 12 threat categories matched to examples; extortion vs sabotage vs espionage vs theft.

WEEK 7

Industry perspective: threats, solutions, challenges

Cyber security: Industry perspective – Parts 1, 2 and 3 (guest lecture by a practitioner)

IN ONE MINUTE

- Cyberspace was built on trust and cooperation, which is why security is hard.
- Five principles: CIA + accountability + auditability (non-repudiation).
- Technical basics: protection rings, symmetric vs public-key encryption, hashing, OSI layers, TCP vs UDP, firewalls, DMZ, VPN.
- Cyber kill chain; vulnerability → exploit → payload; RAT, Trojan, botnet, C2.
- APTs; critical information infrastructure (NCIIPC protects, CERT-In responds); SIEM and SOC.

Why cyberspace is hard to secure

- Gene Spafford's quote: the only truly secure system is switched off, unplugged, locked in a titanium-lined safe, buried in a concrete bunker, surrounded by nerve gas and very highly paid armed guards, "and even then I wouldn't stake my life on it."
- Internet protocols (TCP/IP, BGP routing) were designed for cooperation and trust; they don't validate. Catching rogues in a space built on trust is the root challenge.
- Reported statistics cover only 20–30% of attacks. In digital, "we build the house first and the compound wall later."
- The first cyber attack is usually traced to the Cold War: a **logic bomb** planted in Canadian-sourced control software destroyed a Soviet gas pipeline. Cyberspace has always been in a "no war, no peace" state.
- Definition used: a body of technologies, processes and practices to protect individuals and organisations from cyber crime (and now cyber warfare).
- Five principles: **confidentiality, integrity, availability, accountability** (who changed my data) and **auditability** (changes are recorded and cannot be denied: non-repudiation).

Technical concepts for managers

- **Operating system**: the interface between the human and the hardware (input, output, compute). "All battles are fought in the applications and operating system space."
- **Kernel space vs user space**. **Protection rings**: Ring 0 is most privileged (kernel, full hardware control); rings 1–3 are restricted (user programs in Ring 3). Attackers want kernel-level privilege so they can "pose as the watchman".
- **Symmetric encryption**: one shared key. Problems: how to share the key safely, and if the key is captured later, every past message can be decrypted. The cracking of Germany's Enigma helped the Allies win WWII.
- **Public-key (asymmetric) encryption**: encrypt with the recipient's public key; only their private key decrypts.
- **Hash functions**: one-way; any input gives a fixed-length output; change one bit (one cat whisker) and the whole hash changes. Used to check integrity (the MD5 value next to a download) and in forensics.
- **OSI model**, 7 layers: physical, data link (MAC address), network (IP), transport (TCP/UDP, ports), session, presentation, application. A **port** identifies a process with a network connection.

- **TCP**: reliable, ordered, acknowledgements; slower; used for files. **UDP**: fast, no guarantees; used for streaming, audio and video calls.
- Network access control: **LDAP, Kerberos, RADIUS** identify every user on a network.
- **Firewall**: a security guard at the network's entry and exit enforcing rules. Firewalls at higher layers inspect more and cost more. **DMZ** (demilitarised zone): a buffer zone between the internet and the internal network, reached through a proxy. Unpatched routers and firewalls are "cracks in the wall".
- **VPN** (virtual private network): an encrypted tunnel over the internet that makes a remote user part of the office network. For a hacker it is the "key to the kingdom"; a group is as strong as its weakest member.

How attacks work

Cyber kill chain

Reconnaissance → Weaponization → Delivery → Exploitation → Installation → Command & Control → Actions on objectives

Compared to a commando raid (the film *Uri*): reconnaissance, choosing weapons, getting in, staying in, reporting back.

- **Untargeted** attacks: mass emails, spread through whoever bites. **Targeted** attacks (espionage): focused on you, more expensive, higher risk of exposure.
- **Vulnerability** = the weak point (the thinnest spot of a bunker). **Exploit** = the weaponised means to break through. **Payload** = what does the damage once inside; the deadliest part, and what antivirus mostly looks for. Example: a Word macro vulnerability → exploit downloads code → payload installs a RAT.
- **Malware** is the general term; a **Trojan** is malware that gives the attacker a back door (it can also deliver ransomware). **RAT** = remote administration tool (legitimate ones: TeamViewer; malicious ones sold on the dark web with subscriptions). Key loggers surged after Covid. A **stealer** (e.g. Vidar) steals saved passwords.
- Qbot Trojan: a zip attachment (to dodge email scanners) → Excel file with macros ("enable content") → downloads a DLL → persistence → reports to **C2** (command and control server).
- **Phishing** (random) vs **spear phishing** (researched, targeted; the attacker wants *you*).
- **DoS / DDoS**: volumetric attacks that exhaust bandwidth or connections.
- Top threats (ENISA list): malware, web-based attacks, phishing, web-app attacks, spam, DoS, identity theft, data breaches, insider threats, botnets, physical damage/theft/loss, information leakage, ransomware, cyber espionage, **cryptojacking** (hijacking machines to mine cryptocurrency).

Serious attackers and national defence

- **APT** (Advanced Persistent Threat): well-funded state or criminal groups that do not give up (Indian vaccine makers targeted during Covid). Motives: steal (espionage), disrupt, destroy. The **3 Ds: disrupt, degrade, destroy**.
- Examples: SideCopy (Pakistan-linked; fake version of a government email-security app), Lapsus$ (Microsoft name DEV-0537; recruits insiders over Telegram), Conti; Russia–Ukraine hacktivists. **Attribution is very hard**: a server in China doesn't prove China did it.
- **Critical Information Infrastructure (CII)**: facilities, systems or functions whose incapacity or destruction would have a debilitating impact on national security, governance, economy and social well-being. Defined under the IT Act (Section 70).
- **NCIIPC** (National Critical Information Infrastructure Protection Centre): nodal agency for *protection* (before an attack). Sectors: power & energy; banking, financial services & insurance; telecom; transport;

government; strategic & public enterprises. Sectors depend on each other (power first).

- **CERT-In** (Indian Computer Emergency Response Team): *response* after an incident; empanels auditors ("Safe to Host" certificate). India's National Cyber Security Policy is from 2013 and outdated; too many agencies ("Too many cooks").
- **IT vs OT**: office computers vs operational technology (machinery, SCADA). OT attacks are more dangerous. Examples: Maroochy sewage (fired employee used a radio), Ukraine grid, **Stuxnet** (centrifuges in Iran spun to destruction while screens showed normal speed), Triton, Shamoon.

Defence in practice

- Threat intelligence from the surface, deep and dark web plus your own logs.
- **SIEM** (Security Information and Event Management) collects, correlates and analyses logs and events. A **SOC** (Security Operations Center) acts on SIEM alerts, escalating through analyst levels.
- **EDR** (endpoint detection and response), **MDR** (managed, third party), **XDR** (extended).
- Hierarchy: policy → standards → guidelines → SOPs. Most failures are "slips between the cup and the lip".
- Watch vendors' security; use ML-based anomaly detection (login at 2:30 am, login without a matching access-card swipe).
- Know your attacker's skill: script kiddie (set traps/honeypots), semi-skilled (EDR/XDR), highly skilled (dedicated team, paranoia). Capability is easy to see; motive is hard.
- **Ethical hacker / white hat**: proves a flaw without exploiting it (pops up the calculator). Black hat: malicious. **Red teaming**: consultant-led vulnerability analysis, penetration testing and gap analysis, with only top leadership informed.
- OSINT = public information you have a right to use; leaked dark-web data is neither reliable nor yours to use.

> FROM THE TEXTBOOK (ASKED IN ASSIGNMENTS)
>
> **Accountability**: a person is entrusted with and answerable for equipment, keys or information. **Auditability**: actions can be traced and reviewed through records. **HTTPS** = HTTP over SSL/TLS. Public-key encryption does *not* require sharing the same key. Hash functions give a fixed-length digest and are used in intrusion and virus detection and to build pseudorandom functions.
>
> Firewall types: **packet filtering** (examines each packet against rules), **stateful inspection** (allows/blocks by state, port and protocol), **proxy / application-level** (gateway for a specific application), **next-generation** (stateful plus application awareness, intrusion prevention, threat detection, user identity). Kill chain matching: reconnaissance = gathering data and scanning; weaponization = building the payload; exploitation = triggering code to breach; C2 = remote channel to control the system.

How they'll ask it

- Protection rings (Ring 0 = kernel, most privileged).
- Public-key vs symmetric facts; hash properties; HTTPS = HTTP + SSL/TLS.
- Firewall types matched to descriptions.
- Cyber kill chain stages matched to descriptions.
- Accountability vs auditability; SIEM's purpose; VPN; DDoS diagrams.

WEEK 8

Risk control strategies and security technologies

Cyber security technologies – Parts 1, 2 and 3 · Article: Active Defense and Hacking Back

IN ONE MINUTE

- Five risk control strategies: **defense, transference, mitigation, acceptance, termination**. Defense ≠ mitigation.
- **ALE = SLE × ARO**; **CBA = ALE(prior) − ALE(post) − ACS**.
- Authentication factors; biometrics: FAR, FRR and the CER where they cross.
- Symmetric vs asymmetric keys; digital signatures give non-repudiation.
- Substitution (Caesar), transposition, XOR.
- Active defence vs hacking back: the grey zone and its ethics.

Five risk control strategies

STRATEGY	MEANING	EXAMPLE
Defense	Apply safeguards to prevent the exploit or reduce its chance of success.	Buy firewalls, hire a CISO.
Transference	Shift the risk to someone else.	Outsourcing, managed services, cloud, insurance (iPremier → Qdata, done badly).
Mitigation	Reduce the *impact* once an attack happens.	Contingency planning, hot sites.
Acceptance	Knowingly do nothing more, with economic justification.	Many academic institutions; "Target can absorb the fine."
Termination	Stop the activity or drop the asset because protecting it costs too much.	Shut the business unit or sell the asset.

NIST SP 800-30 and ISO 27005 use different names for the same ideas. Every choice needs economic justification.

Cost-benefit analysis

```
SLE  = asset value × exposure factor        (single loss expectancy)
ALE  = SLE × ARO                             (ARO = annualised rate of occurrence)
CBA  = ALE(prior) − ALE(post) − ACS          (ACS = annualised cost of safeguard)
Justified when ALE(post) + ACS < ALE(prior)
```

After choosing a control, keep monitoring it: the estimate and the actual results can differ.

> QUICK CHECKS FROM ASSIGNMENT 8
>
> SLE ₹8 lakh, ALE ₹12 lakh → ARO = 12 / 8 = 1.5. AV ₹15 lakh, EF 40%, twice a year → ALE = 15 × 0.4 × 2 = ₹12 lakh. ALE 20 → 8 lakh, ACS 3 lakh → CBA = 20 − 8 − 3 = ₹9 lakh.

Access control technology

- Films the professor recommends: Orwell's *1984* (book written 1949; surveillance, power asymmetry; also read *Animal Farm*), *Minority Report* (2002; retina scans).

- Identification in the old days used permanent body marks ("a mole on the right cheek").
- Authentication factors: **something you know** (password, passphrase, PIN), **something you have** (smart card, token, phone for OTP), **something you are** (fingerprint, retina, iris), **something you produce** (voice, signature).
- Multi-factor example, SBI login: username (claim), password (factor 1), CAPTCHA (proves you are human), OTP on your phone (factor 2).
- Biometric ration distribution in Krishna district, Andhra Pradesh: labourers' fingerprint ridges were worn, so the system used all five fingers.

Biometric errors

MEASURE	MEANING
FAR	False Acceptance Rate: impostors accepted (false positive, type II). Falls as sensitivity rises.
FRR	False Rejection Rate: genuine users rejected (false negative, type I). Rises as sensitivity rises.
CER	Crossover Error Rate: where FAR = FRR. The optimal setting; lower CER = better device.

CAT-cutoff analogy: set it at 99.99 and you keep out weak students (few false positives) but reject good ones (more false negatives).

Most-used biometrics: fingerprint, retina (blood-vessel pattern), iris (freckles, pits, striations, vasculature, coronas).

Firewalls and DMZ

The firewall decides who (e.g. which IP address) may reach what. The **trusted network** is yours; anything external is **untrusted**. The **DMZ** holds copies of services for outsiders, so they never touch the trusted network directly.

Cryptography

- Cryptography doesn't stop access; it assumes someone gets the data and makes it unreadable. *Kryptos* = hidden. WhatsApp's end-to-end encryption means only sender and receiver can read.
- Vocabulary: plaintext, cipher, ciphertext (cryptogram), encrypt/encipher, decrypt/decipher, key; data is encrypted in blocks of bits.
- **Symmetric key**: one key; simple, but the key must travel over an insecure network.
- **Asymmetric key**: the recipient's public key encrypts; only her private key decrypts. (Like a TSA luggage lock: one master key.)
- **Digital signature**: the reverse. The sender signs with her *private* key; anyone verifies with her public key. Provides **non-repudiation** (you can't deny a signed cheque). India's MCA21 company e-filing used digital-signature dongles. **Digital certificates** (from a certificate authority) prove a website is genuine.

Three basic encryption methods

- **Substitution**. Monoalphabetic: Caesar cipher, $C = (P + k) \bmod 26$ with $k = 3$, so "MEET ME AFTER THE TOGA PARTY" becomes "PHHW PH DIWHU WKH WRJD SDUWB". Polyalphabetic: a different shift for each letter from a key; DOMS with key IITM gives LWFE.
- **Transposition**: rearranges positions of bits/characters within a block according to the key.
- **XOR**: combine each bit with a key bit; same bits → 0, different → 1.

Article: Active Defense and Hacking Back (Scott Berinato, HBR)

- Interviews with **Dorothy Denning** (Naval Postgraduate School) and **Robert M. Lee** (co-founder, Dragos, which identified ICS-attacking malware in 2017).
- Sun Tzu: "Security against defeat implies defensive tactics; ability to defeat the enemy means taking the offensive." Mao Zedong: "The only real defense is active defense."
- Denning's definition: active defence is a **direct defensive action taken to destroy, nullify, or reduce the effectiveness of a cyber threat** against friendly assets. Properly understood, it is neither offensive nor necessarily dangerous.
- Georgia case: a Russian hacker searched government files for "USA" and "NATO". Georgia planted spyware in a fake "NATO" document; when stolen, it took the hacker's webcam photo.
- Arguments for hacking back: gather intelligence, find what was stolen, identify the attacker for law enforcement. Against: likely illegal, may hit innocent intermediaries (hospitals, universities), no proof it works, can compromise government operations.
- DHS describes a **grey zone** from passive defence (antivirus, firewalls) through information sharing, honeypots, deception, hunting, beacons, botnet takedowns, white-hat ransomware rescues, to offensive hack-back. Further right = more risk and more impact.
- Denning's ethical principles: **authority, third-party immunity, necessity, proportionality, human involvement, civil liberties**.

> FROM THE TEXTBOOK (ASKED IN ASSIGNMENTS)
>
> **Risk assessment** is not "identify, assess and reduce": that definition belongs to **risk management**. Risk identification = recognising, enumerating and documenting risks, including classifying, valuing and prioritising assets. **Identification** = claiming an identity; **authentication** = verifying the claim. To stop someone denying they approved a purchase order, use their **digital signature (private key)**. A **Certificate Authority (CA)** vouches that a public key belongs to a website.

How they'll ask it

- Five risk control strategies matched to scenarios (watch defense vs mitigation).
- Numericals: SLE, ALE, ARO, CBA.
- FAR, FRR, CER on a graph.
- Identification vs authentication; digital signature for non-repudiation; CA for certificates.
- Caesar cipher encoding; active defence ethics.

Quick recall

1. **Five risk control strategies?**
   → Defense, transference, mitigation, acceptance, termination.
2. **Defense vs mitigation?**
   → Defense prevents or reduces the chance of attack; mitigation reduces impact after it happens.
3. **Example of transference?**
   → Outsourcing, managed services, cloud, insurance.
4. **SLE formula?**
   → Asset value × exposure factor.